Systems Requirements Specification: Privacy Preserving Data Analytics Engine (E-Privacy)

Dilmith D. L. S., Hansana O. G. V., Vidyananda K. H. K.

August 21, 2026

1 Introduction

1.1 Purpose

This document specifies the system requirements for the **Privacy Preserving Data Analytics Engine (PPDAE)**, hereafter referred to as "the Engine." It builds directly on the security requirements and vulnerability analysis established in Deliverable 1 (Pre-Study), which concluded that the "Data-in-Use" plaintext exposure window is the primary architectural flaw of conventional analytics platforms and that pseudo-anonymization is defeated by linkage attacks. This Deliverable translates those findings into a concrete requirements specification for a system that computes on encrypted data without ever decrypting it server-side.

1.2 Scope

The Engine allows a Data Owner (e.g. a hospital, bank, or research institute) to outsource statistical aggregation – sums, averages, counts – of sensitive records to an untrusted cloud environment while cryptographically guaranteeing that the cloud never observes plaintext values. The scope of this deliverable covers functional and non-functional requirements, system architecture, data flow, and the empirical justification for the selected cryptographic scheme. Full production hardening (multi-party computation, differential privacy noise injection, complex query languages) is out of scope for this phase and is listed under Assumptions and Future Work.

1.3 Assumptions

Since the target production environment, exact dataset types, and organizational infrastructure were not specified, the following assumptions were made to scope this SRS:

A1. The Engine targets **additive aggregate analytics** (sum, average, count, weighted average) as the primary workload, consistent with the Feasibility PoC. Complex joins, non-linear functions (e.g. median, standard deviation without a secondary protocol) are deferred to a later phase.

A2. The **Data Owner is a single trusted entity** per deployment (e.g. one hospital) that holds the private key; multi-owner federated aggregation is a future extension requiring threshold cryptography.

A3. The cloud provider is treated as **honest-but-curious**: it will follow the protocol correctly but will attempt to learn as much as possible from ciphertext and metadata. Active/Byzantine cloud behavior is mitigated only by the verifiable computation log, not prevented outright.

A4. Dataset volumes are in the range demonstrated in the Computation Overhead study (approximately 2×10^6 records / 100 MB per batch); the Engine must degrade gracefully, not necessarily linearly, beyond this.

A5. Network transport (TLS 1.3) and at-rest storage encryption (AES-256) are assumed already compliant per the organization's existing infrastructure and are treated as satisfied preconditions, not engineering deliverables of this project.

A6. Key management uses a Hardware Security Module (HSM) or equivalent secure enclave on the Data Owner side; the Engine does not implement its own HSM but integrates with one via a standard interface (e.g. PKCS#11).

2 System Architecture

The Engine partitions responsibility across a trusted Data Owner domain and an untrusted Cloud Analytics Engine domain, directly closing the "Data-in-Use" gap identified in Figure 1 of Deliverable 1: plaintext never crosses the domain boundary in either direction.

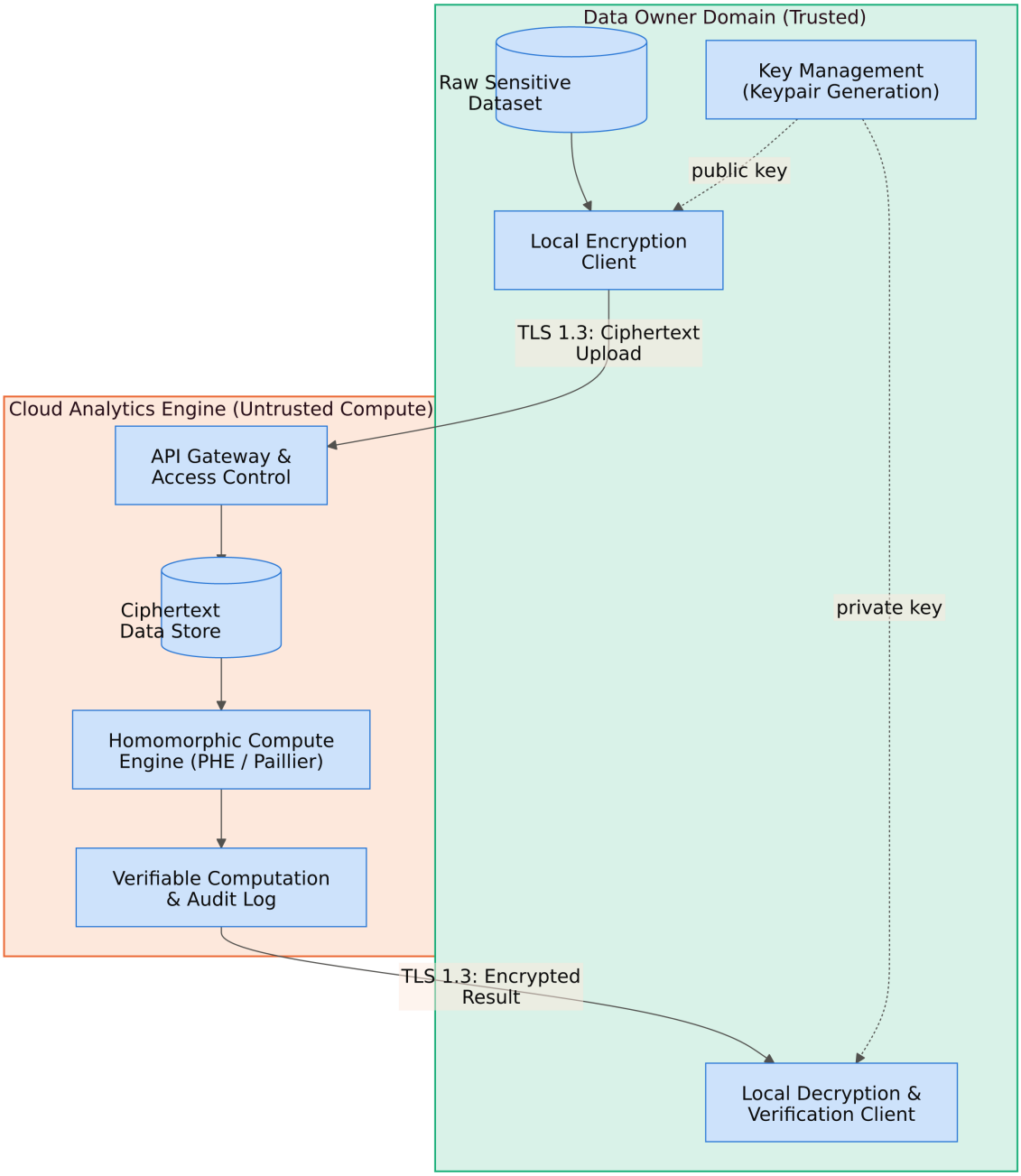


Figure 1: High-level system architecture: encryption and decryption occur exclusively within the trusted Data Owner domain; the cloud only ever manipulates ciphertext.

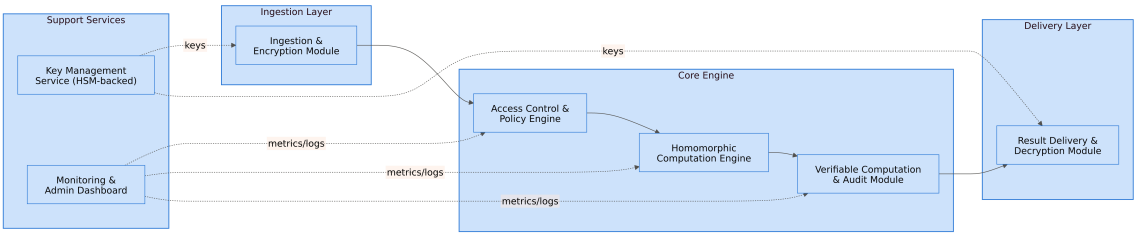


Figure 2: Component/module breakdown of the Engine across the ingestion, core computation, support, and delivery layers.

2.1 End-to-End Data Flow

Figure 3 traces a single analytics request end-to-end, showing exactly where the private key is used (only within the Data Owner domain, steps 1–2 and 9–10) and where the cloud only ever handles ciphertext.

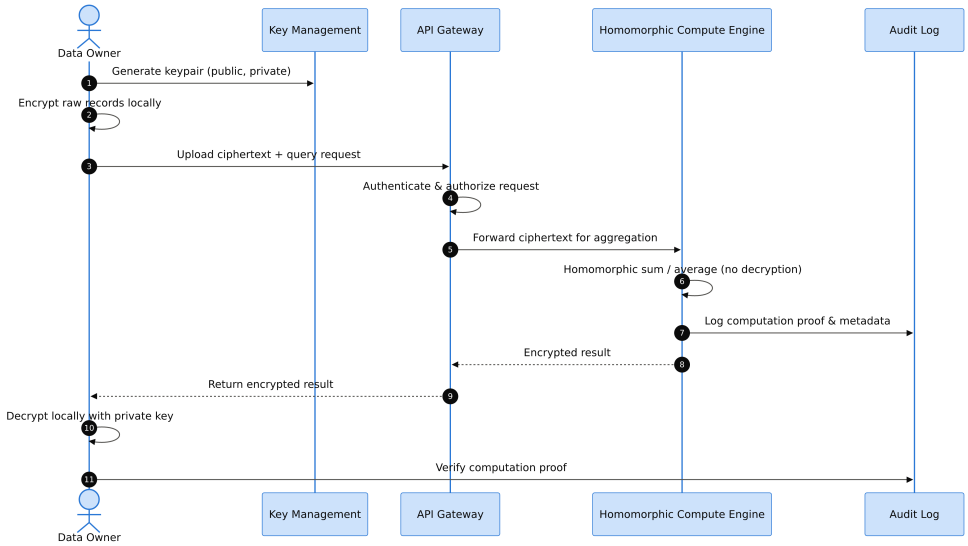


Figure 3: Sequence of operations for a homomorphic aggregation query.

3 Functional Requirements

ID	Requirement	Description
FR-1	Local Key Generation	The Data Owner client must generate a Paillier (or equivalent additively homomorphic) keypair locally; the private key must never leave the trusted domain.
FR-2	Client-Side Encryption	Raw records must be encrypted on the Data Owner's infrastructure before any network transmission.
FR-3	Homomorphic Aggregation	The cloud engine must compute sum, average, and count directly over ciphertext without decryption, using additive homomorphism and plaintext-scalar multiplication.
FR-4	Access Control & Policy Engine	The API Gateway must authenticate and authorize every query request against a role-based policy before ciphertext is released to the compute engine.
FR-5	Result Return & Local Decryption	Aggregated encrypted results must be returned to the Data Owner and decrypted only within the trusted domain.
FR-6	Verifiable Computation Log	Every computation must emit an auditable, tamper-evident log entry (operation type, input ciphertext hashes, timestamp) so the Data Owner can verify correctness.
FR-7	Multi-Key-Length Support	The Engine must support configurable key bit-lengths (at minimum 1024/2048/3072) so operators can trade off security margin against latency.
FR-8	Admin Monitoring Dashboard	Operators must be able to observe query throughput, latency, and storage consumption without access to any private key or plaintext.

Table 1: Functional Requirements

3.1 Requirement Prioritization

Figure 4 maps each functional requirement against implementation effort and business impact, informing the phased delivery plan: homomorphic aggregation and local key management are the two "must-ship-first" capabilities, since every other requirement depends on them.

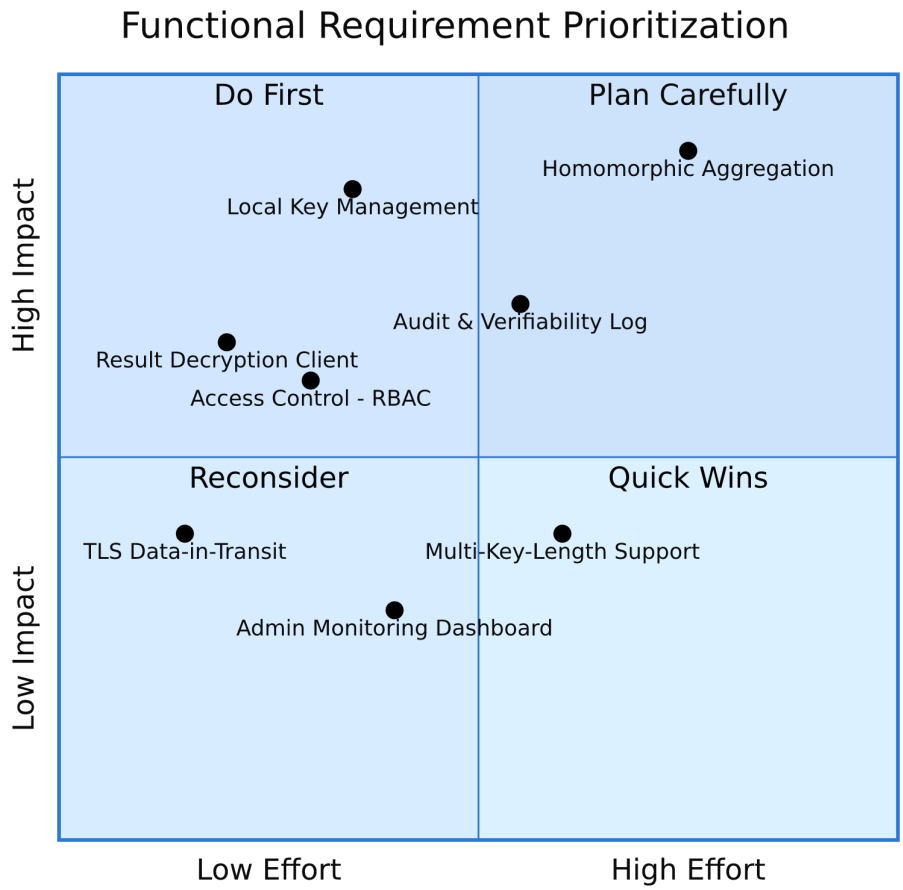


Figure 4: Functional requirement prioritization by impact vs. implementation effort.

4 Non-Functional Requirements

Category	Requirement
Confidentiality	No plaintext sensitive value may exist outside the Data Owner's trusted domain at any point in the pipeline, satisfying the Confidentiality requirement of Deliverable 1.
Integrity & Verifiability	Every cloud-side computation must be independently verifiable against the audit log; unauthorized modification of stored ciphertext must be detectable (e.g. via authenticated encryption / MAC on ciphertext blobs).
Performance	Analytics latency must remain within an operator-configured SLA per key length; based on the empirical study (Section 5), a 2048-bit PHE deployment should target sub-5-minute aggregation latency for a 2M-record batch.
Scalability	The compute engine must horizontally scale ciphertext summation across worker nodes, since Paillier summation is embarrassingly parallel.
Storage Efficiency	Ciphertext storage expansion must be bounded and predictable; based on Section 5, PHE at 2048-bit keys is budgeted at $\leq$ 1.1 GB per 100 MB of plaintext (an $\sim$11x expansion), versus FHE's $\sim$650x.
Availability	The API Gateway and compute engine must meet a 99.5% uptime target, independent of the Data Owner's local infrastructure availability.
Auditability	All access-control decisions and computations must be logged with sufficient metadata for post-hoc compliance review (e.g. HIPAA, GDPR-style audits), without logging plaintext.
Usability	The client-side encryption/decryption library must expose a single-call API (encrypt/aggregate/decrypt) so integration effort for a new Data Owner is under one engineer-week.

Table 2: Non-Functional Requirements

5 Empirical Justification of Cryptographic Scheme Selection

To ground the Engine's design in evidence rather than assumption, the Feasibility and Computation Overhead studies benchmarked four candidate approaches – **Plaintext** (baseline), **RSA** (decrypt-compute-re-encrypt), **PHE / Paillier** (additive homomorphism), and **FHE / TenSEAL CKKS** (arbitrary homomorphism) – across key lengths of 1024, 2048, and 3072 bits, extrapolated from a 1,000-record sample to the full 2,000,000-record / 94.76 MB financial dataset (a 2000x scale factor).

5.1 Storage Footprint

Figure 5 shows that FHE ciphertext expansion is catastrophic for tabular aggregation workloads (up to 617 GB for a 94.76 MB source file, a ∼6,600x expansion), while PHE remains within a manageable ∼11–16x expansion across all tested key lengths.

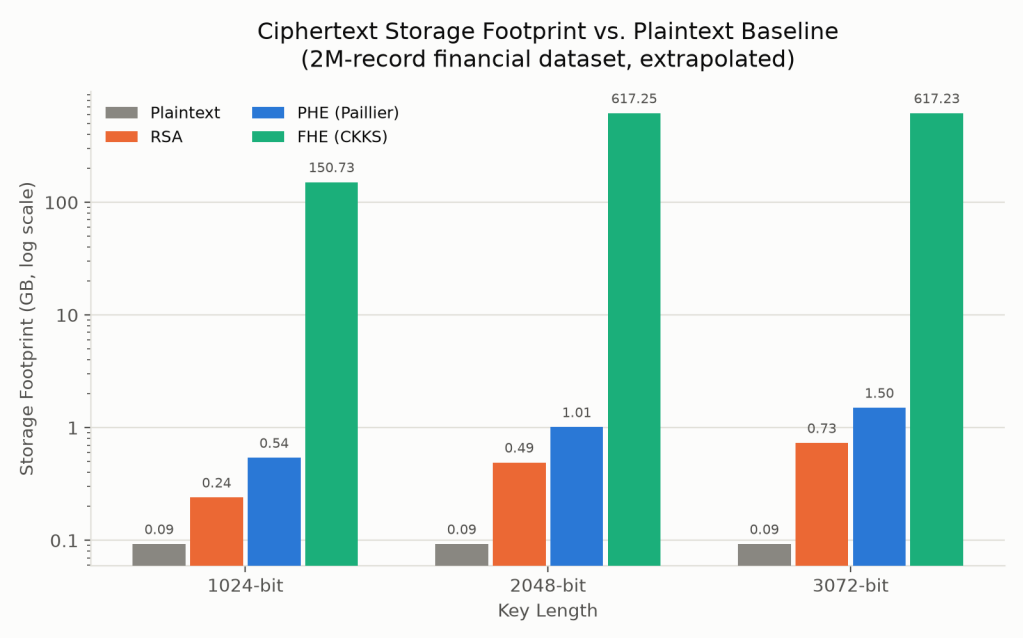


Figure 5: Ciphertext storage footprint by cryptographic scheme and key length (log scale).

5.2 Encryption Latency

Figure 6 shows the full-dataset encryption latency. PHE encryption is the slowest to *ingest* at higher key lengths (112 hours at 3072-bit), which drives NFR guidance to default to 2048-bit keys and to parallelize/pipeline ingestion rather than block on full-dataset encryption before any query can run.

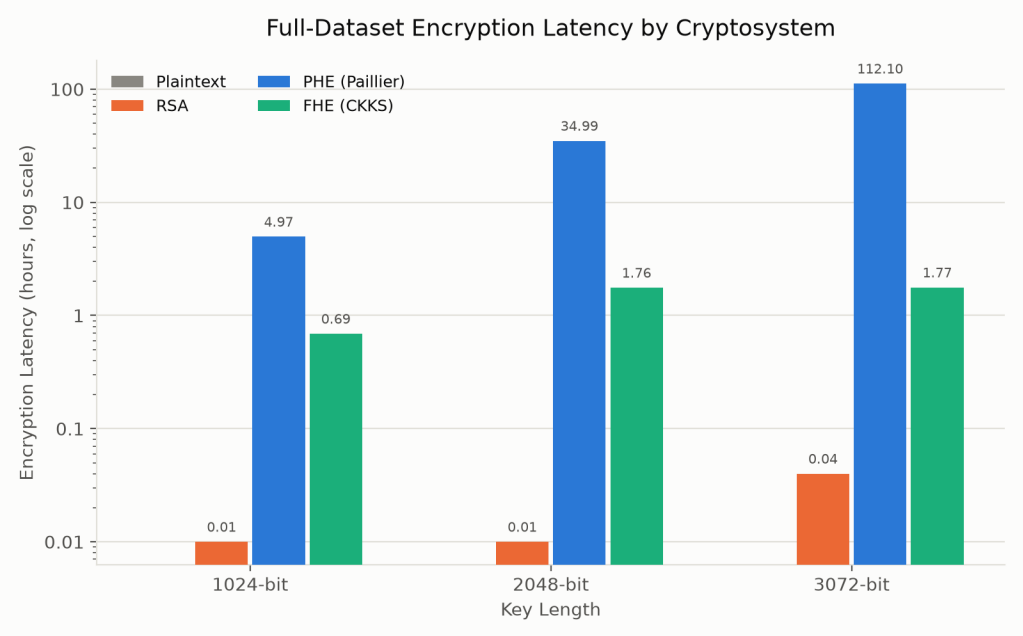


Figure 6: Full-dataset encryption latency by cryptographic scheme and key length (log scale).

5.3 Analytics (Query) Latency

Figure 7 shows the latency of the actual sum/average computation on already-encrypted data – the metric that dominates user-perceived query responsiveness. PHE outperforms both RSA's decrypt-compute-re-encrypt pipeline (which additionally violates the Data-in-Use confidentiality requirement) and FHE at every key length tested.

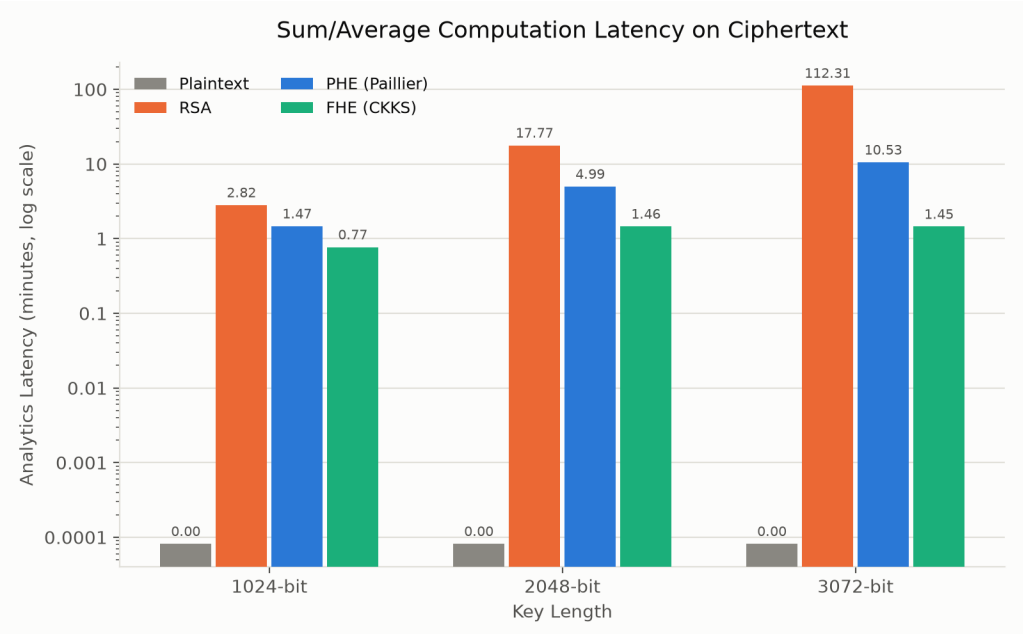


Figure 7: Ciphertext sum/average computation latency by cryptographic scheme and key length (log scale).

5.4 Trade-off Synthesis

Figure 8 plots storage footprint against analytics latency for the three encrypted schemes. PHE occupies the most favorable region of the trade-off space – low storage expansion *and* low query latency – for additive aggregation workloads, whereas FHE's generality is paid for with orders-of-magnitude worse storage and no corresponding analytics-latency benefit for this workload class.

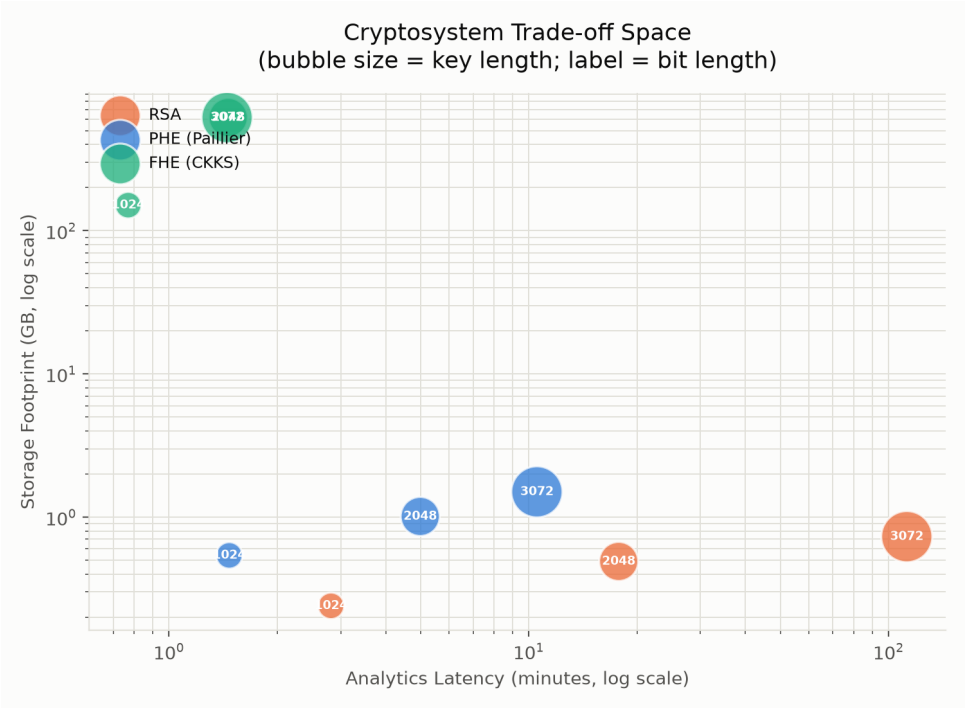


Figure 8: Storage footprint vs. analytics latency trade-off space across cryptosystems and key lengths.

5.5 Decision

Based on this empirical evidence, the Engine's **Homomorphic Computation Engine (FR-3) is specified around Partially Homomorphic Encryption (Paillier)** at a default 2048-bit key length, matching the industry-standard security margin while keeping storage expansion and analytics latency within operationally acceptable bounds. FHE (CKKS) is retained as a *pluggable future option* (per A1) for workloads that require multiplicative operations between two ciphertexts, which Paillier does not support.

6 Requirements Traceability

Deliverable 1 Security Requirement	Addressed By	Req. ID
Confidentiality	Client-side encryption; no server-side decryption ever occurs	FR-1, FR-2, FR-3
Integrity	Tamper-evident audit log; authenticated ciphertext storage	FR-6
Anonymity	Aggregation-only query surface prevents record-level linkage; direct identifiers never leave the trusted domain	FR-2, FR-4
Verifiability	Verifiable computation log independently checkable by the Data Owner	FR-6

Table 3: Traceability from Deliverable 1 security requirements to Deliverable 2 functional requirements.

7 Constraints and Future Work

- Paillier's lack of native ciphertext-ciphertext multiplication limits the Engine to linear aggregate statistics in this phase; variance/standard-deviation queries require either a two-round protocol or a partial FHE fallback.
- Encryption latency at higher key lengths (Figure 6) motivates a streaming/incremental ingestion pipeline rather than a batch-encrypt-then-query model, to be detailed in the subsequent design deliverable.
- Multi-owner federated queries and differential-privacy noise injection for output perturbation are explicitly deferred (A2, A1) and should be scoped in a follow-on SRS revision.

8 Conclusion

This SRS translates the security requirements and architectural flaw analysis of Deliverable 1 into a concrete, empirically justified system design. By confining plaintext exclusively to the Data Owner's trusted domain and performing all cloud-side analytics via Partially Homomorphic Encryption, the Engine closes the Data-in-Use vulnerability window while remaining within practical storage and latency budgets, as demonstrated by the benchmarking data in Section 5.